R8: hasło do bazy trafiło do GitHub

Rezerwowe pytanie, możliwe odpowiedzi i wyjaśnienia dla prowadzącego

Data Platform Engineer / AWS DevOps · przewodnik po polsku · 18 października 2026

Pytanie na 2-4 minuty, gdy kandydat nie zna któregoś głównego tematu lub rozmowa przebiega szybciej. Nie wymaga kodowania, komend Git ani konfiguracji AWS. Rozmowa z kandydatem pozostaje po angielsku.

Scenariusz łączy GitHub, obsługę sekretów i weryfikację działania platformy. To przykład dydaktyczny, nie zarzut ani opis zdarzenia u poprzedniego pracodawcy. Odpowiedź oceniaj w obszarze bezpieczeństwa i pracy operacyjnej.

Zachowaj 60 minut i końcowe pięć minut na pytania kandydata. Zapisz osobno zadeklarowany brak wiedzy w pominiętym temacie. R8 nie zastępuje dowodu znajomości Terraform, Pythona czy sieci.

Spis treści

1. Pytanie i kiedy go użyć 2
2. Pojęcia, które musisz rozumieć 2
3. Co daje nowy commit, a czego nie naprawia 3
4. Przykład poprawnej reakcji krok po kroku 3
5. Secrets Manager zmieniony, a job nadal nie działa 4
6. Możliwe odpowiedzi kandydata i dopytania 4
7. Przykładowa odpowiedź, czas i ocena 5
8. Ściąga przed zadaniem pytania 6

1. Pytanie i kiedy go użyć

> “You discover that a database password was committed to a GitHub repository used by an AWS data pipeline. A teammate removes it in a new commit and says the problem is solved. Do you agree? What would you do next, and how would you check that the pipeline still works?”

Po polsku: hasło do bazy trafiło do repozytorium używanego przez platformę danych. Kolega usunął je nowym commitem. Czy wystarczy, co zrobić dalej i jak sprawdzić, że dane nadal mogą być przetwarzane?

Pytanie sprawdza rozumienie trzech spraw: kopii sekretu, ważności poświadczenia oraz przywrócenia poprawnego działania. Kandydat może odpowiedzieć prostymi słowami. Nie musi znać nazw narzędzi do przepisywania historii Git.

Po pominiętym temacie:

> “Thank you for clarifying. Let's switch to a short scenario about handling secrets.”

Przy zapasie czasu:

> “We have a few minutes available. I'd like to ask one short additional scenario about handling secrets.”

Nie podawaj od razu podpowiedzi „musisz zmienić hasło”. Pozwól kandydatowi samodzielnie ocenić wypowiedź kolegi.

2. Pojęcia, które musisz rozumieć

Pojęcie	Proste wyjaśnienie
Repozytorium	Miejsce przechowywania kodu i historii jego zmian
Commit	Zapis określonej wersji; późniejszy commit nie wymazuje automatycznie wcześniejszych
Sekret	Poufna wartość, np. hasło, token lub tajna część klucza
Poświadczenie	Informacja używana do potwierdzenia dostępu, np. użytkownik i hasło
Ujawnienie	Udostępnienie wartości poza przeznaczonym dla niej sposobem przechowywania
Unieważnienie	Odebranie poświadczeniu możliwości dalszego użycia
Rotacja	Zmiana poświadczenia i przełączenie jego uprawnionych odbiorców
Odbiorca/konsument sekretu	Job lub aplikacja, która używa wartości, np. do logowania do bazy
Secrets Manager	Usługa przechowywania i kontrolowanego udostępniania sekretów
Cache	Zapamiętana wcześniej wartość lub połączenie, nieodświeżane przy każdym użyciu

Istotne rozróżnienie: hasło do bazy i uprawnienia roli AWS to różne elementy. Job może mieć prawo pobrać sekret z AWS, a mimo to nie zalogować się do bazy, bo pobrana wartość nie odpowiada jej aktualnemu hasłu.

Nie utożsamiaj też ujawnienia z potwierdzonym włamaniem. Trzeba ograniczyć ryzyko i zbadać dostępne dowody; nie wolno bez danych zapewniać, że nikt nie skorzystał z hasła albo że na pewno doszło do kradzieży danych.

3. Co daje nowy commit, a czego nie naprawia

Przykład: commit A zawiera hasło w konfiguracji. Commit B usuwa je z pliku. Osoba oglądająca aktualny plik w B nie widzi wartości, ale wcześniejsza wersja mogła zostać odczytana lub skopiowana.

Stan	Co zostało osiągnięte	Co nadal trzeba ustalić
Hasło usunięte z aktualnego pliku	Nie jest dalej publikowane w tej wersji	Czy działa i gdzie zostały kopie
Hasło unieważnione/zmienione w systemie	Stara wartość nie powinna pozwalać na nowe uwierzytelnienie	Czy odbiorcy działają i czy były inne skutki
Historia repozytorium oczyszczona	Ograniczono dostępność wartości w uzgodnionym zakresie	Jakie kopie pozostają poza tym zakresem

GitHub zaleca jako pierwszy krok unieważnienie lub rotację ujawnionego sekretu. Przepisywanie historii wymaga koordynacji i nie gwarantuje usunięcia cudzych kopii. GitHub: usuwanie danych wrażliwych.

> “If someone copied the password before the new commit, would deleting the file stop it from working?”

To dobra podpowiedź, jeśli kandydat skupia się wyłącznie na Git. Zapisz, że została użyta. Nie wymagaj wykonywania force-push ani usuwania repozytorium.

4. Przykład poprawnej reakcji krok po kroku

1. Ustalam, jaki system i poświadczenie są dotknięte oraz angażuję właściciela incydentu i bazy zgodnie z procedurą. Nie rozpowszechniam wartości dalej.
2. Organizuję szybkie ograniczenie ryzyka: unieważnienie lub rotację ujawnionego poświadczenia. Kolejność zależy od zagrożenia i systemu; nie odkładam zabezpieczenia tylko po to, by najpierw porządkować historię.
3. Ustalam odbiorców: które zadania, aplikacje i środowiska korzystają z hasła oraz skąd je pobierają.
4. Uzgadniam nowe poświadczenie w bazie, jego bezpieczny zapis i przełączenie odbiorców. Pilność może oznaczać świadomie zaakceptowaną przerwę.
5. Sprawdzam, że stare poświadczenie nie umożliwia nowego logowania, a właściwy job używa nowego i wykonuje oczekiwaną operację.
6. Osobno wyjaśniam zakres ujawnienia, możliwe inne kopie, potrzebę czyszczenia historii i działania zapobiegające powtórzeniu.

Na poziomie bazowym wystarczy wyjaśnienie tej logiki, nie pełny plan reagowania na incydenty. Jeśli kandydat nie jest administratorem bazy, dobra odpowiedź może wskazać właściwego właściciela i własne zadania weryfikacyjne.

Nie wymagaj, żeby dowolna baza akceptowała dwa hasła naraz. Nie zakładaj, że zmiana hasła automatycznie zamknie wszystkie aktywne sesje. Takie szczegóły zależą od danego systemu i są dodatkową głębią, a nie podstawą krótkiego pytania.

5. Secrets Manager zmieniony, a job nadal nie działa

> “The value in Secrets Manager was updated, but the job still fails. What would you check?”

To opcjonalne dopytanie na dłuższy wariant. Wystarczą dwa lub trzy trafne sprawdzenia związane z konkretnym błędem, nie pełna lista poniżej.

Możliwa przyczyna	Co sprawdzić
Zmieniono tylko zapisany tekst, nie hasło bazy	Czy system docelowy rzeczywiście akceptuje nowe poświadczenie
Job czyta inny sekret	Właściwe środowisko, referencja i wersja sekretu
Proces zachował starą wartość	Sposób odświeżania, cache lub istniejące połączenie
Brak dostępu do magazynu	Rzeczywista rola i dokładny błąd pobierania
Połączenie do bazy nie dochodzi	Osiągalność i charakter błędu, zamiast ponownej zmiany hasła w ciemno
Logowanie działa, operacja jest zabroniona	Uprawnienia użytkownika bazy do oczekiwanego działania

W rotacji trzeba uzgodnić poświadczenia w magazynie oraz w bazie/usłudze. Samo wpisanie nowej wartości nie dowodzi wykonania obu kroków. AWS: rotacja sekretów.

Dowód przywrócenia: job z właściwego środowiska wykonuje dozwoloną operację, a oczekiwany wynik trafia do odbiorcy. Status „sekret zapisano” potwierdza tylko zapis. Nie proś o wklejenie prawdziwego hasła w ramach testu.

6. Możliwe odpowiedzi kandydata i dopytania

Kandydat mówi	Dopytanie po angielsku	Co oceniasz
“The new commit fixed it.”	“What about the previous commit and any copies?”	Rozumienie historii i kopii
“The repository is private.”	“Who or what could still have read the credential?”	Prywatność nie jest dowodem braku ekspozycji
“I would rotate the password.”	“How would you know the intended job uses the replacement?”	Skutek dla odbiorców, nie sama nazwa procesu
“I would force-push a clean history.”	“Would the copied password still work before revocation?”	Kolejność ograniczania ryzyka
“I would put it in Secrets Manager.”	“What changes in the database and the consumer?”	Zgodność trzech miejsc
“I would add it to .gitignore.”	“What happens to copies already committed?”	Prewencja a obsługa istniejącego ujawnienia
“I did not configure rotation myself.”	“What could you verify and who would you involve?”	Uczciwa granica odpowiedzialności

Przy pytaniu o zapobieganie akceptuj sekrety poza kodem, kontrolowany dostęp w czasie wykonania, review oraz odpowiednie skanowanie. Nazwanie jednego skanera nie jest obowiązkowe i nie dowodzi wykrywania każdego rodzaju sekretu.

Nie oczekuj od kandydata twierdzenia, że miał taki incydent. Może poprawnie rozwiązać hipotetyczny scenariusz i osobno wskazać, co rzeczywiście robił.

7. Przykładowa odpowiedź, czas i ocena

> “No. The password may still be in Git history or other copies. I would treat it as exposed and involve the incident and database owners so the credential is revoked or rotated promptly. We need to coordinate the database, the stored secret and its consumers. I would verify that the old credential no longer works and that the intended job performs an authorised operation with the replacement, without logging the values. History cleanup would be a separate coordinated action, and I would address how the secret entered Git.”

Dwie minuty: około 30 sekund na pytanie i namysł, minuta na odpowiedź, 30 sekund na jedno wyjaśnienie. **Cztery minuty:** po podstawie dodaj jedno dopytanie z rozdziału 5 lub 6. Nie odczytuj wszystkich pytań z tabeli.

Ocena pomocnicza	Zaobserwowany dowód
1	Mimo wyjaśnienia uznaje samo usunięcie pliku za pełne zabezpieczenie hasła
2	Dochodzi do rotacji i sprawdzenia odbiorcy z istotnymi podpowiedziami
3	Samodzielnie łączy ważność hasła, przełączenie odbiorców i sprawdzenie działania
4	Dodatkowo uzasadnia koordynację, wpływ i granice dowodów na konkretnym przykładzie
N/O	Nie zebrano wystarczających dowodów w tym obszarze

Zapisz: podstawowa decyzja, dowód działania, użyta podpowiedź i własne doświadczenie. Nie dodawaj osobnej wagi R8 do arkusza, jeśli oceniasz już te same umiejętności w bezpieczeństwie/operacjach. Nie przyznawaj punktów za Terraform na podstawie tej odpowiedzi.

8. Ściąga przed zadaniem pytania

Pytanie: hasło w Git, usunięte kolejnym commitem. Czy wystarczy?

Odpowiedź bazowa: nie; obsłużyć ujawnione poświadczenie, nie tylko plik. Unieważnić lub zmienić z właścicielami systemu, przełączyć odbiorców i sprawdzić prawdziwe działanie. Czyszczenie historii jest osobną decyzją.

Trzy rzeczy, których słuchasz:

- Stara wartość nie powinna umożliwiać dalszego nowego logowania.
- Baza, zapisany sekret i konfiguracja joba są uzgodnione.
- Właściwy job wykonuje dozwoloną operację i dostarcza oczekiwany wynik.

Dopytanie przy zapasie czasu:

> “The value in Secrets Manager was updated, but the job still fails. What would you check?”

Słabe skróty do wyjaśnienia: „private, więc bezpieczne”, „usunę commit”, „zrestartuję”, „wkleję hasło do logu”. Sprawdź intencję przed oceną.

Nie wymagaj: kodu, komend Git, pełnego protokołu rotacji ani deklaracji osobistego udziału w wycieku.

Czas: 2-4 minuty w ramach godziny. Pozostaw końcowe pięć minut kandydatowi. Wiedzę o pominiętym temacie oceniaj wyłącznie na podstawie dowodów z tego tematu.

Materiały powiązane: plan rozmowy, przykładowe odpowiedzi.